

Relazione tecnica progetto mensile

Analisi delle vulnerabilit  e azioni di rimedio su Metasploitable

D'Angelo Giovanni

Corso: Cyber Security & Ethical Hacking

Modulo / progetto: M3_S4_E2

In questo progetto ho eseguito una scansione completa del target Metasploitable, ho selezionato quattro vulnerabilit  critiche o ad alto impatto tra quelle pi  esposte e ho implementato una serie di azioni di rimedio direttamente sulla macchina bersaglio. L'obiettivo non era solo correggere i servizi pi  problematici, ma anche dimostrare in modo verificabile l'efficacia delle modifiche attraverso confronti prima/dopo con Nmap e con una seconda scansione Nessus.

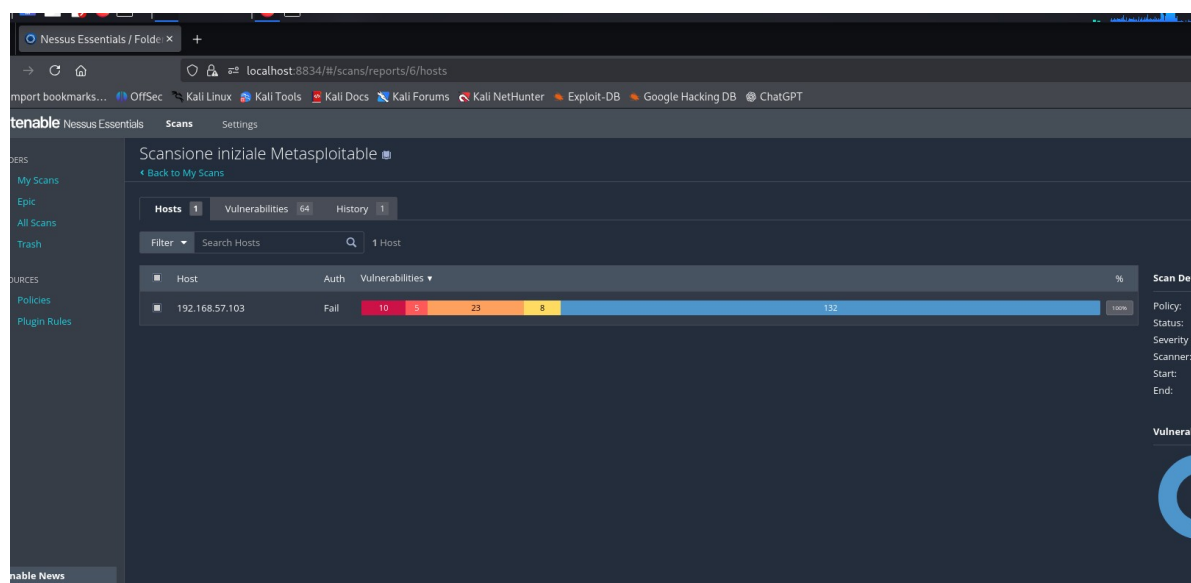


Figura 1 - Sintesi della scansione iniziale Nessus sul target 192.168.57.103.

1. Obiettivo e impostazione del progetto

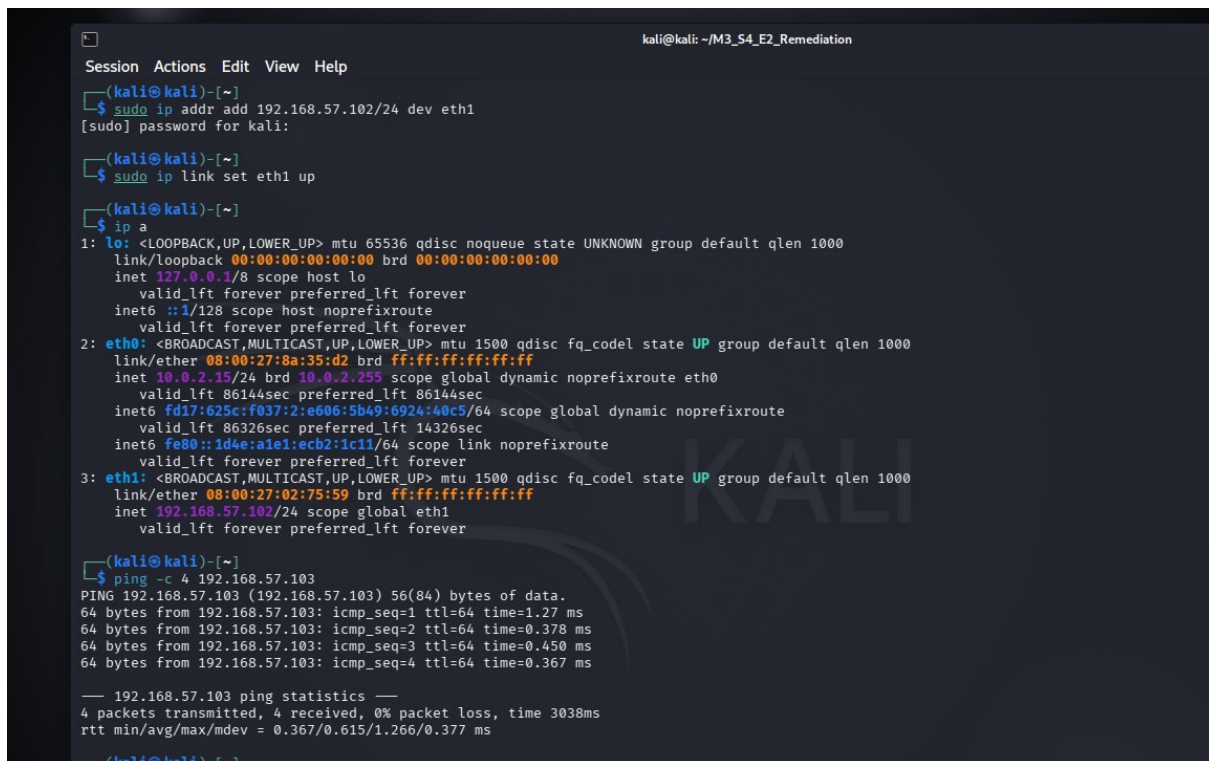
La traccia del progetto richiedeva di effettuare una scansione completa del target Metasploitable, scegliere da un minimo di 2 a un massimo di 4 vulnerabilità critiche e implementare delle azioni di rimedio, verificandone poi l'efficacia con una scansione finale di confronto. Era inoltre possibile consegnare un report unico, soluzione che ho scelto per mantenere in un solo documento l'intero percorso tecnico.

Ho deciso di concentrare il lavoro su quattro esposizioni concrete e direttamente verificabili anche da riga di comando: NFS Exported Share Information Disclosure, rexecd Service Detection, Bind Shell Backdoor Detection e VNC Server "password" Password. Questa scelta mi ha permesso di lavorare su servizi realmente raggiungibili in rete, documentando non solo le modifiche applicate, ma anche i problemi incontrati durante la remediation e il modo in cui li ho risolti.

2. Ambiente di laboratorio

La macchina sorgente utilizzata per tutte le attività è stata Kali Linux. La configurazione mostrava una prima interfaccia già configurata sulla rete 10.0.2.0/24 e una seconda interfaccia eth1 dedicata al laboratorio. Per raggiungere correttamente Metasploitable ho configurato manualmente su eth1 l'indirizzo 192.168.57.102/24 e ho portato l'interfaccia in stato UP, verificando subito dopo la raggiungibilità del target con il ping.

Il target Metasploitable era attestato sull'indirizzo 192.168.57.103. Per organizzare il progetto ho creato una struttura di lavoro dedicata, separando scansioni, cartella remediation, screenshot, report e output Nmap. Questa impostazione iniziale si è rivelata utile per mantenere ordine durante un lavoro lungo, composto da molte prove, modifiche e controlli incrociati.



```
kali@kali: ~/M3_S4_E2_Remediation
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo ip addr add 192.168.57.102/24 dev eth1
[sudo] password for kali:
(kali@kali)-[~]
$ sudo ip link set eth1 up
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 86144sec preferred_lft 86144sec
    inet6 fd17:625c:f037:2:e606:5b49:6924:40c5/64 scope global dynamic noprefixroute
        valid_lft 86326sec preferred_lft 14326sec
    inet6 fe80::1d4e:a1e1:ecb2:1c11/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:02:75:59 brd ff:ff:ff:ff:ff:ff
    inet 192.168.57.102/24 scope global eth1
        valid_lft forever preferred_lft forever
(kali@kali)-[~]
$ ping -c 4 192.168.57.103
PING 192.168.57.103 (192.168.57.103) 56(84) bytes of data:
64 bytes from 192.168.57.103: icmp_seq=1 ttl=64 time=1.27 ms
64 bytes from 192.168.57.103: icmp_seq=2 ttl=64 time=0.378 ms
64 bytes from 192.168.57.103: icmp_seq=3 ttl=64 time=0.450 ms
64 bytes from 192.168.57.103: icmp_seq=4 ttl=64 time=0.367 ms

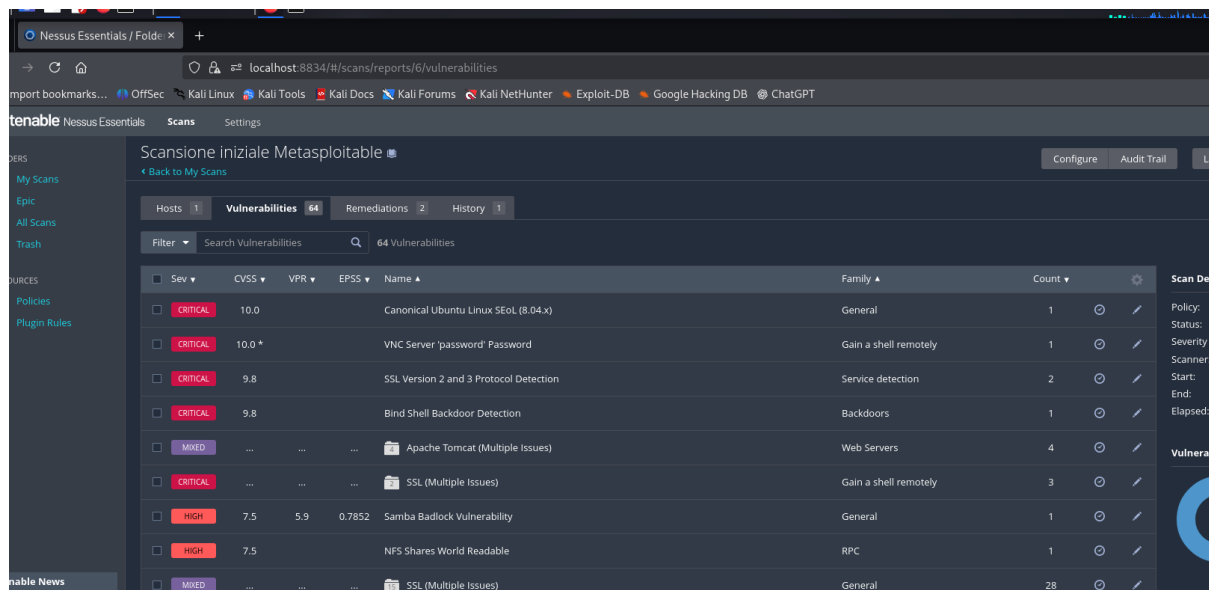
— 192.168.57.103 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3038ms
rtt min/avg/max/mdev = 0.367/0.615/1.266/0.377 ms
(kali@kali)-[~]
```

Figura 2 - Configurazione dell'interfaccia di laboratorio su Kali e verifica della connettività verso Metasploitable.

3. Scansione iniziale e selezione delle vulnerabilita

La scansione iniziale Nessus sul target 192.168.57.103 ha restituito 64 voci aggregate. A livello di severita, il quadro iniziale era composto da 10 criticita, 5 vulnerabilita high, 23 medium, 8 low e 132 informazioni di contesto. Gia da questa vista generale era evidente che il sistema esponeva numerosi servizi legacy o insicuri.

Analizzando il dettaglio delle vulnerabilita ho individuato come prioritarie quattro esposizioni coerenti con la traccia del progetto: il servizio NFS esportato in modo troppo permissivo, il servizio rexecd in ascolto sulla porta 512/tcp, la bind shell backdoor sulla porta 1524/tcp e il servizio VNC raggiungibile con password debole o di default. Ho affiancato all'evidenza Nessus una verifica tecnica con Nmap, cosi da avere un riscontro diretto porta per porta prima di iniziare la remediation.



Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Canonical Ubuntu Linux SEOL (8.04.x)	General	1
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5	5.9	0.7852	Samba Badlock Vulnerability	General	1
HIGH	7.5			NFS Shares World Readable	RPC	1
MIXED	...	...	...	SSL (Multiple Issues)	General	28

Figura 3 - Elenco iniziale delle vulnerabilita rilevate da Nessus sul target.

```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)~$ mkdir -p ~/M3_S4_E2_Remediation/nmap
sudo nmap -sV -p 111,512,5900,1524,2049 192.168.57.103 -oN ~/M3_S4_E2_Remediation/nmap/pre_remediation_servizi.txt
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 08:58 -0400
Nmap scan report for 192.168.57.103
Host is up (0.00042s latency).

PORT      STATE SERVICE      VERSION
111/tcp    open  rpcbind      2 (RPC #100000)
512/tcp    open  exec         netkit-rsh rexecd
1524/tcp   open  bindshell    Metasploitable root shell
2049/tcp   open  nfs          2-4 (RPC #100003)
5900/tcp   open  vnc          VNC (protocol 3.3)
MAC Address: 08:00:27:FE:97:50 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.84 seconds

(kali@kali)~$ cat ~/M3_S4_E2_Remediation/nmap/pre_remediation_servizi.txt
# Nmap 7.99 scan initiated Sun Jun 28 08:58:25 2026 as: /usr/lib/nmap/nmap -sV -p 111,512,5900,1524,2049 -oN /home/kali/M3_S4_E2_Remediation/pre_remediation_servizi.txt
Nmap scan report for 192.168.57.103
Host is up (0.00042s latency).

PORT      STATE SERVICE      VERSION
111/tcp    open  rpcbind      2 (RPC #100000)
512/tcp    open  exec         netkit-rsh rexecd
1524/tcp   open  bindshell    Metasploitable root shell
2049/tcp   open  nfs          2-4 (RPC #100003)
5900/tcp   open  vnc          VNC (protocol 3.3)
MAC Address: 08:00:27:FE:97:50 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Jun 28 08:58:38 2026 -- 1 IP address (1 host up) scanned in 12.84 seconds

(kali@kali)~$
```

Figura 4 - Verifica Nmap pre-remediation sui servizi selezionati: 111, 512, 1524, 2049 e 5900.

Prima di passare alla fase di remediation ho sintetizzato il perimetro dei servizi scelti nel seguente riepilogo:

Vulnerabilit� selezionata	Evidenza iniziale	Servizio / porta	Obiettivo di rimedio
NFS Exported Share Information Disclosure	Export visibile con showmount e 2049/tcp open	nfs / 2049	Rimuovere export e disattivare il servizio NFS
rexecd Service Detection	Servizio exec individuato da Nmap	exec / 512	Disabilitare la riga rexec e riavviare il servizio corretto
Bind Shell Backdoor Detection	Shell in ascolto senza autenticazione	ingreslock / 1524	Commentare la riga inetd/xinetd e chiudere la porta
VNC Server "password" Password	5900/tcp open e accesso VNC debole	vnc / 5900	Terminare il processo Xtightvnc e verificare la chiusura della porta

4. Remediation della condivisione NFS

La prima attivita che ho affrontato   stata la vulnerabilit  collegata a NFS. Prima della modifica ho verificato con showmount che il target stava esportando la condivisione in modo estremamente permissivo, con un export visibile dall'esterno. La scansione mirata confermava inoltre la presenza della porta 2049/tcp aperta, insieme al servizio rpcbind sulla 111/tcp.

Durante questa fase ho incontrato subito un errore operativo banale ma significativo: nel tentativo di creare il backup del file /etc/exports ho digitato il percorso come se fosse una directory (/etc/exports/), ottenendo

l'errore "cannot stat ... Not a directory". Ho corretto immediatamente il comando, ho creato il backup corretto del file, poi ho aperto /etc/exports e ho commentato la riga che esportava tutto il filesystem in lettura/scrittura con no_root_squash.

Dopo la modifica del file ho ricaricato la configurazione di export e ho fermato il servizio nfs-kernel-server, rimuovendolo anche dalla sequenza di avvio. La verifica finale ha dato un risultato netto: showmount non e piu riuscito a interrogare il servizio e la scansione Nmap ha mostrato la porta 2049/tcp chiusa, mentre la 111/tcp risultava ancora aperta come rpcbind.

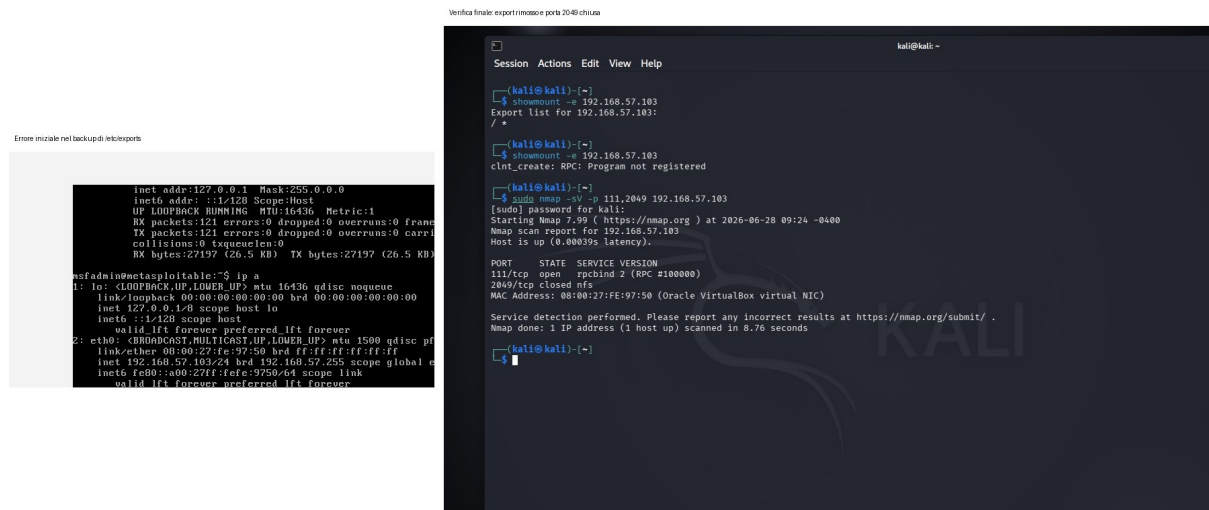


Figura 5 - Fase NFS: errore iniziale nel backup del file exports e verifica conclusiva della chiusura del servizio.

5. Remediation del servizio rexec

Il secondo intervento ha riguardato rexecd, rilevato inizialmente come servizio exec in ascolto sulla porta 512/tcp. Ho eseguito una scansione mirata per isolare il problema, poi sono passato sulla macchina Metasploitable per individuare la riga di configurazione responsabile all'interno di /etc/inetd.conf. Dopo aver eseguito il backup del file, ho commentato la riga relativa a rexec.

Anche in questa parte il lavoro non e stato lineare. Dopo il salvataggio del file ho provato a riavviare il servizio utilizzando un path errato e, successivamente, ho tentato di usare il comando service, che su quel sistema non era disponibile. In un altro passaggio, uscendo dall'editor, ho digitato un semplice "y" nel terminale e il sistema mi ha risposto con "command not found". Questi errori mi hanno costretto a fermarmi, verificare i processi attivi con ps aux e controllare gli script presenti in /etc/init.d.

La parte decisiva del troubleshooting e stata capire che il listener sulla 512/tcp non era realmente gestito come mi aspettavo da openbsd-inetd, ma da xinetd. Solo dopo avere eseguito la ricerca nei file di configurazione e il restart di xinetd, il listener sulla porta 512 e scomparso. La verifica finale con netstat e poi con Nmap ha confermato la remediation: 512/tcp risultava chiusa.

Tentativo di restart non corretto e troubleshooting del servizio

Correzione finale: restart di xinetd e porta 512 non più in ascolto

```
# exec stream tcp nowait root /usr/sbin/tcpd
ingreslock stream tcp nowait root /bin/bash bash -i

[Wrote 8 lines]

root@metasploitable:/home/nsfadmin# /etc/init.d/openbsd-inetd
bash: /etc/init.d/openbsd-inetd: No such file or directory
root@metasploitable:/home/nsfadmin# service openbsd-inetd restart
* debian-helper-scripts
* sysvconfig
Try: apt-get install <selected package>
bash: service: command not found
root@metasploitable:/home/nsfadmin# /etc/init.d/openbsd-inetd
root@metasploitable:/home/nsfadmin# ps aux | grep -i inetd
root      4540  0.0  0.1  2424   864 ?        Ss   07:46
d -pidfile /var/run/xinetd.pid -stayalive -inetd_compat
root      6097  0.0  0.1  3004   776 tty1    R+   10:09
root@metasploitable:/home/nsfadmin# ls /etc/init.d | grep -i
openbsd-inetd
xinetd
root@metasploitable:/home/nsfadmin# /etc/init.d/openbsd-inetd
root@metasploitable:/home/nsfadmin# netstat -tulpn | grep :512
tcp        0      0  0.0.0.0:512          0.0.0.0:*
4540/xinetd
root@metasploitable:/home/nsfadmin# grep -Rni "rexec\|in.rex
td.d/* 2>/dev/null
root@metasploitable:/home/nsfadmin# grep -Rni "rexec\|in.rex
```

Figura 6 - Fase rexec: troubleshooting del restart e correzione finale con riavvio di xinetd.

6. Remediation della bind shell sulla porta 1524

Una delle evidenze più gravi dell'intero progetto era la bind shell in ascolto sulla porta 1524/tcp, riconosciuta da Nmap come "Metasploitable root shell". Questa vulnerabilità era particolarmente critica perché consentiva l'esposizione di una shell remota senza un meccanismo di autenticazione adeguato.

Per risolvere il problema ho individuato in /etc/inetd.conf la riga ingreslock che avviava /bin/bash in modalità interattiva. Ho commentato la riga incriminata, quindi ho riavviato xinetd per applicare la modifica. In questa fase ho preferito verificare prima con netstat l'assenza del listener e poi con Nmap l'effettiva variazione dello stato della porta.

Il confronto prima/dopo è stato molto chiaro: nella prima verifica la porta 1524 risultava open, mentre dopo la modifica e il riavvio del servizio la stessa porta risultava closed. Questo mi ha dato una conferma immediata della riuscita della remediation anche prima del rescans Nessus.

```
kali@kali: ~
Session Actions Edit View Help
MAC Address: 08:00:27:FE:97:50 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.75 seconds

(kali@kali)-[~]
$ sudo nmap -sV -p 512 192.168.57.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 10:25 -0400
Nmap scan report for 192.168.57.103
Host is up (0.00038s latency).

PORT      STATE SERVICE VERSION
512/tcp   closed exec
MAC Address: 08:00:27:FE:97:50 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.67 seconds

(kali@kali)-[~]
$ sudo nmap -sV -p 1524 192.168.57.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 10:28 -0400
Nmap scan report for 192.168.57.103
Host is up (0.00036s latency).

PORT      STATE SERVICE VERSION
1524/tcp  open  bindshell Metasploitable root shell
MAC Address: 08:00:27:FE:97:50 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.74 seconds

(kali@kali)-[~]
$ sudo nmap -sV -p 1524 192.168.57.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 10:31 -0400
Nmap scan report for 192.168.57.103
Host is up (0.00041s latency).

PORT      STATE SERVICE VERSION
1524/tcp  closed ingreslock
MAC Address: 08:00:27:FE:97:50 (Oracle VirtualBox virtual NIC)
```

Figura 7 - Confronto Nmap sulla bind shell: porta 1524 aperta prima della modifica e chiusa dopo il riavvio di xinetd.

7. Remediation del servizio VNC

L'ultima vulnerabilità affrontata è stata il servizio VNC in ascolto sulla porta 5900/tcp, che Nessus identificava come accessibile con una password debole o di default. La scansione iniziale Nmap confermava la presenza del servizio VNC protocol 3.3.

Per intervenire ho individuato il processo in esecuzione con ps aux e ho verificato con netstat che la porta 5900 era effettivamente in stato LISTEN. Anche qui il percorso non è stato immediato: nei primi tentativi ho utilizzato comandi di terminazione troppo generici o digitati in modo impreciso, che non hanno prodotto subito il risultato atteso. Solo dopo avere affinato il filtro e avere terminato il processo Xtightvnc in maniera mirata, il processo è scomparso e la porta ha smesso di essere esposta.

La verifica finale da Kali ha mostrato in modo inequivocabile che 5900/tcp, inizialmente open, era diventata closed. Questo passaggio è stato importante anche perché dimostra come, in un progetto reale, la parte più lunga non sia soltanto eseguire il comando giusto, ma capire quale processo stia davvero generando l'esposizione e come chiuderlo senza lasciare listener attivi.

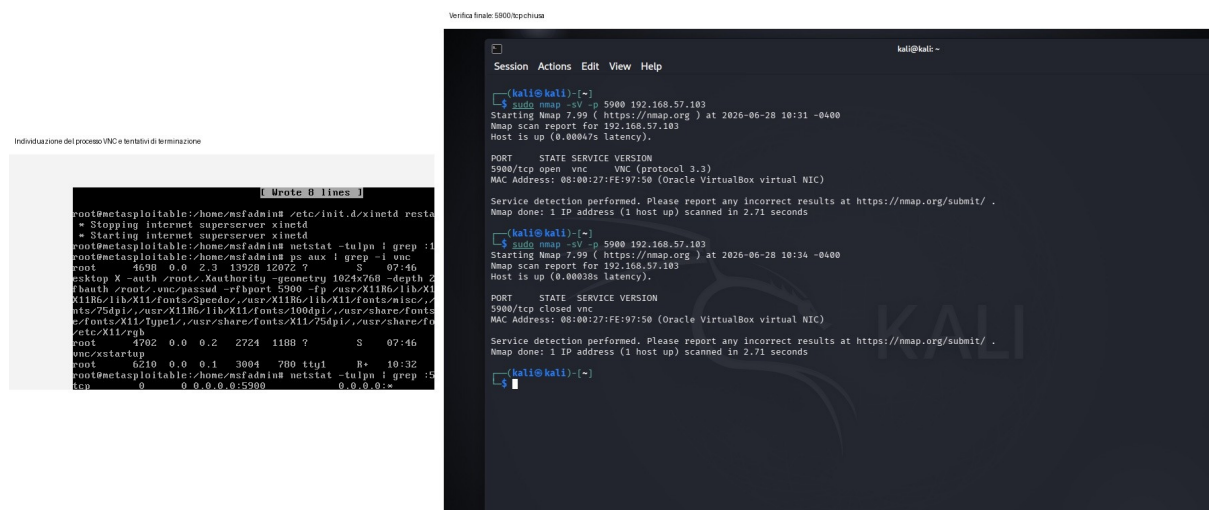


Figura 8 - Fase VNC: identificazione del processo esposto, tentativi di arresto e verifica finale della chiusura della porta 5900.

8. Confronto prima/dopo e verifica finale

Terminati i quattro interventi ho eseguito una nuova verifica mirata con Nmap sul set di porte scelto all'inizio del progetto. Il confronto tra pre_remediation_servizi.txt e post_remediation_servizi.txt ha evidenziato un miglioramento netto: il target continuava a esporre solo rpcbind sulla 111/tcp, mentre 512/tcp, 1524/tcp, 2049/tcp e 5900/tcp risultavano tutte chiuse.

Successivamente ho creato ed eseguito una nuova scansione Nessus finale sullo stesso target. Il rescans non ha annullato tutte le criticità della macchina, cosa prevedibile su un sistema volutamente vulnerabile e molto datato, ma ha comunque mostrato un miglioramento misurabile. Le voci aggregate sono passate da 64 a 59; le criticità sono scese da 10 a 7, le high da 5 a 4, le medium da 23 a 22, le low da 8 a 7 e le informazioni da 132 a 114.

L'aspetto piu importante, pero, non e stato soltanto la riduzione numerica. Nel dettaglio delle vulnerabilita finali non comparivano piu le esposizioni che avevo scelto come obiettivo del progetto, cioe NFS export disclosure, rexec, bind shell e VNC con password debole. Rimanevano invece vulnerabilita strutturali o di piattaforma, come il sistema operativo obsoleto, alcune problematiche SSL e altre esposizioni applicative piu profonde, che richiederebbero interventi di aggiornamento, hardening o sostituzione del servizio e non una semplice chiusura di porta.

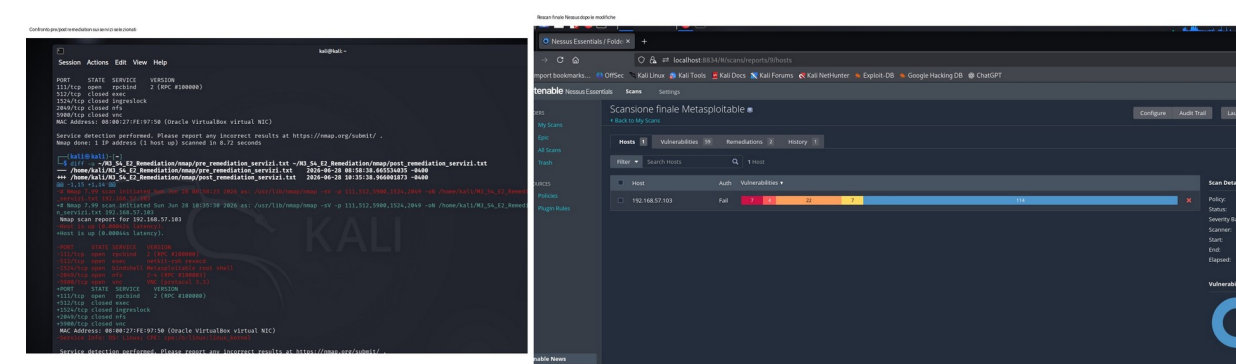


Figura 9 - Confronto finale tra output Nmap prima/dopo e sintesi del rescans Nessus conclusivo.

Per avere una vista sintetica del miglioramento ottenuto, ho riportato i dati principali nel seguente riepilogo:

Indicatore	Scansione iniziale	Scansione finale
Voci aggregate	64	59
Critical	10	7
High	5	4
Medium	23	22
Low	8	7
Info	132	114
Servizi selezionati aperti	111, 512, 1524, 2049, 5900	111
Servizi selezionati chiusi	-	512, 1524, 2049, 5900

9. Conclusioni finali

Questo progetto mi ha permesso di affrontare in modo concreto un ciclo completo di vulnerability assessment e remediation: scansione iniziale, scelta delle priorit , intervento sui servizi esposti, troubleshooting degli errori, validazione tecnica puntuale e rescans conclusivo. Il lavoro non e stato lineare e proprio per questo e stato formativo: diverse volte ho dovuto fermarmi, rileggere l'output, correggere il comando o cambiare approccio prima di arrivare alla soluzione corretta.

La parte piu importante dal punto di vista didattico e che ogni rimedio non e stato dato per scontato, ma e stato verificato con piu strumenti: showmount, netstat, ps, grep, Nmap e infine Nessus. Questo mi ha permesso di dimostrare non solo di avere applicato delle modifiche, ma di avere compreso perche una vulnerabilita era presente, quale servizio la generava e quale effetto produceva la correzione.

Ritengo quindi il progetto riuscito in maniera positiva. Le quattro esposizioni selezionate all'inizio sono state gestite e non risultano piu presenti nelle verifiche mirate finali. Allo stesso tempo, il rescans Nessus ha mostrato che la macchina conserva altre criticita strutturali, elemento coerente con la natura di

Metasploitable. Questo rende il progetto ancora piu utile, perche evidenzia la differenza tra remediation puntuale di singoli servizi e hardening complessivo di un sistema vulnerabile.